

PeerLink KACST Failed-Login Protection Test Record

Classification: Internal working evidence; sanitize before external submission **Test date:** 2026-08-11 AST **Environment:** Isolated local acceptance plus OCI production **Production release:** Application c525585 ; final deployed verification bdb03b5 (workflow 31539611417) **Source branch:** feature/kacst-failed-login-protection , released through hamza-backend

Acceptance Configuration

Setting	Production source value	Isolated test value
Failure threshold	5 attempts	5 attempts
Lockout duration	15 minutes	12 seconds
State store	PostgreSQL	Isolated PostgreSQL 16
Application mode	Production	ENVIRONMENT=test

The threshold was not shortened. Only the recovery timer was accelerated. The override is ignored outside test mode and unit tests verify that production continues to use 15 minutes.

Automated and Static Validation

Check	Result
Failed-login, session-security, and auth regression unit tests	PASS — 32 tests
Existing input/security validation suite	PASS — 126 checks
Frontend production build and targeted lint	PASS
Python compilation	PASS
Alembic upgrade, downgrade, and re-upgrade	PASS
Alembic upgrade with startup-created table already present	PASS
Main local backend migration and authentication smoke test	PASS — revision at head, health 200, generic 401
Production Docker Compose validation	PASS
Development Docker Compose validation	PASS
Isolated acceptance Compose validation	PASS
Alembic migration to f4a9c2d78110	PASS locally and in OCI production
Deployed production image unit/regression suite	PASS — 32 tests
Live production unknown-account threshold	PASS — 401 attempts 1–4; 429 attempts 5–6; generic body throughout
Production test-row cleanup	PASS — unique HMAC-keyed acceptance row removed
Source diff whitespace validation	PASS

Controlled Acceptance Results

The repeatable runner is `scripts/run_failed_login_acceptance.py`. It does not print credentials, hashes, cookies, session handles, or tokens.

ID	Test	Expected	Actual	Result
FL-01	Administrator failures 1–4	Generic HTTP 401	Generic HTTP 401 each time	PASS
FL-02	Administrator failure 5	Protection activates; generic HTTP 429 and <code>Retry-After</code>	Activated on fifth failure	PASS
FL-03	Correct administrator password during lock	Password verification blocked	Generic HTTP 429	PASS
FL-04	Normal-user failures 1–4	Generic HTTP 401	Generic HTTP 401 each time	PASS
FL-05	Normal-user failure 5	Protection activates	Generic HTTP 429 and <code>Retry-After</code>	PASS
FL-06	Correct normal-user password during lock	Password verification blocked	Generic HTTP 429	PASS
FL-07	Unknown identifier attempts 1–5	Same sequence and body as existing account	Byte-equivalent message and same status sequence	PASS
FL-08	Five concurrent failures	Four 401 results and one threshold 429; next request blocked	Atomic expected sequence observed	PASS
FL-09	Timer recovery	Correct password accepted after accelerated expiry	Authentication continued to normal post-password flow	PASS
FL-10	Successful-login reset	Next wrong password starts at attempt one	HTTP 401, not immediate lock	PASS
FL-11	Persistence privacy	No plaintext email column in shared state	Only HMAC identity key stored	PASS
FL-12	Production override guard	12-second test value ignored in production	15-minute production duration selected	PASS
FL-13	Rendered login UI after fifth failure	Show only generic authentication feedback	Generic message rendered; no account or lock wording	PASS

BrowserOps UI Evidence

- Task: `20260811-143546-peerlink-failed-login-local-acceptance`
- Final screenshot: `screenshots/011-fifth-failure-generic-protection-state.png`
- Rendered text: `texts/011-fifth-failure-generic-protection-state.txt`

The BrowserOps evidence was captured from the real isolated frontend at localhost. It is not a generated or mock screenshot.

Generic Feedback Evidence

The controlled response body for wrong credentials, unknown identifiers, the fifth failure, and active lockout is:

```
{"status":"ERROR","message":"Invalid email or password. Please try again later."}
```

The record intentionally excludes usable test credentials and response tokens.

Acceptance Conclusion

Item 2 is implemented locally and deployed to OCI production. The isolated test demonstrates administrator/member behavior, concurrency safety, recovery, reset, and anti-enumeration. Production workflow 31531595809 independently confirmed the five-attempt/15-minute runtime values, applied migration, passed 32 tests inside the deployed image, and proved the live unknown-account 401 → 429 threshold while preserving generic feedback.

Remaining Review Evidence

- Optional controlled real-account normal-user and administrator screenshots in an approved window.
- Optional literal 15-minute wall-clock recovery capture.
- Internal Hamza/Aadil sign-off.

This record claims production deployment and technical verification, not KACST acceptance or reviewer approval.

Generated from the approved internal report source for Aadil Feroze's review. Do not forward to KACST without internal approval.